# Основе информационе безбедности

Практикум

## 0.1 Како користити практикум

Практикум прати садржај вежби из информационе безбедности. Свака тема обухвата проблем, примењене контроле, типичне грешке и начин провере донете одлуке. Након вежбе студент треба да уме да образложи обрађени принцип и примени га у оквиру додељене пројектне целине.

**Примена на пројекту**

Сваки тим ради на свим додељеним пројектним целинама из СКУТУМ спецификације и обрађене принципе примењује на сопствени домен. Две контролне тачке, КТ1 у термину 4. вежбе и КТ2 у термину 8. вежбе, прате напредак целог додељеног обухвата; додатни захтеви за тимове са три целине наведени су посебно.

*Табела 1. Фаза и Препоручени начин рада*

| Фаза | Препоручени начин рада |
|---|---|
| Пре вежбе | Прочитати тему и издвојити претпоставке које би у информационом систему могле бити погрешне. |
| Током вежбе | Повезати појам са последицама у развоју информационог система, а не само са називом класе или крајње тачке Програмски интерфејс-ја. |
| После вежбе | Применити принцип на примеру система и документовати резултат тестом, одлуком или ревизијским записом. |
| Пред одбрану | Објаснити проблем, изабрану контролу, њено ограничење и начин на који је понашање проверено. |

**Дефанзивна оријентација**

Практикум не захтева развој експлоита, малвера ни напад на реалне системе. Сумњива активност, грешка конфигурације или покушај недозвољеног приступа репродукују се контролисаним симулаторима и тестним идентитетима.

**Језик и алати**

Примери су претежно у Ц шарп и дотнет окружењу. Друга технологија може бити одобрена када тим обезбеди интероперабилност и еквивалентан ниво тестирања и безбедносне контроле.

## 0.2 Ток градива

Осам вежби обрађује идентитет и приступ, заштиту података, безбедносне политике, границе поверења, реаговање на инциденте, процену ризика и унапређивање контрола. Теме су распоређене тако да се свака наредна ослања на претходно уведене појмове.

- Идентитет и Контрола приступа заснована на улогама: ко приступа систему, са којим правом и зашто.
- Ауторизација и подаци: одлука над конкретним ресурсом и осетљивост информације.
- Политике и границе поверења: правила, конфигурација, имовина и моделовање претњи.
- Оперативна безбедност: сесије, Вишефакторска аутентикација, тајне, детекција и инцидент.
- Напредне одлуке: контекстуална правила, ризик, корелација и доказ ефективности.

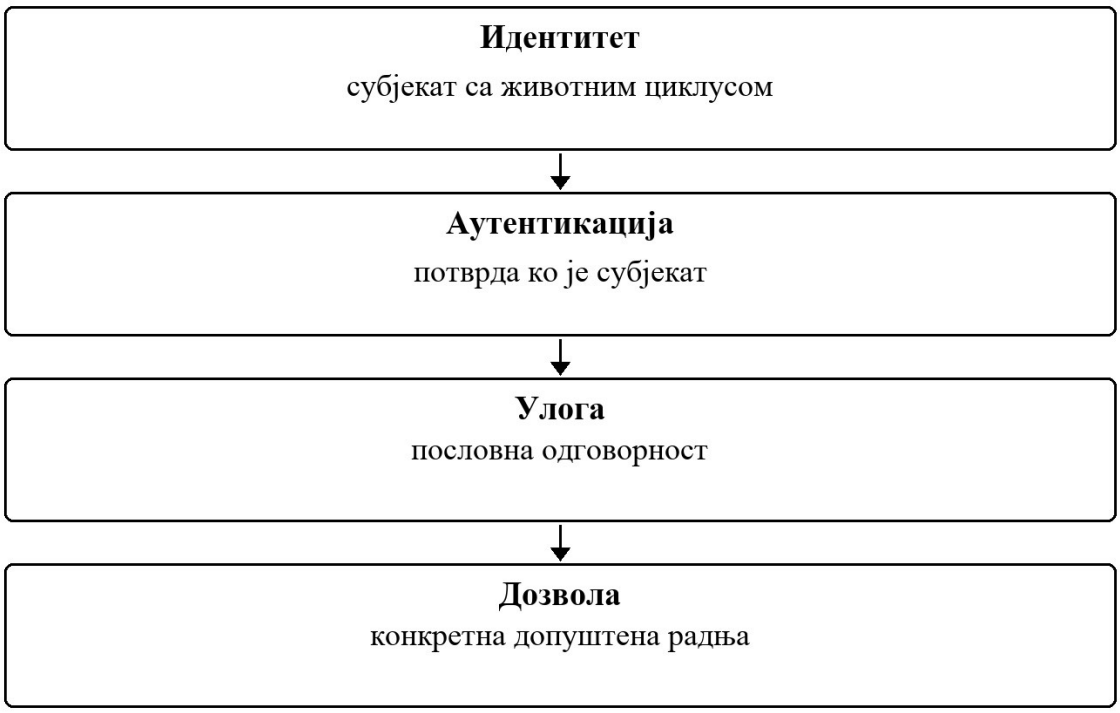
Контролне тачке се одржавају у терминима 4. и 8. вежбе: КТ1 проверава основну имплементацију и безбедносни модел, а КТ2 завршну демонстрацију и провера безбедносног квалитета. Контролне тачке и термини одбране пројекта су одвојене обавезе. Теме вежби дају подршку раду, док редослед имплементације свих додељених целина тим одређује према спецификацији и њиховим предусловима.

- КТ1 (Вежба 1–4, Вежба 4) — Основна имплементација и безбедносни модел.
- КТ2 (Вежба 5–8, Вежба 8) — Завршна демонстрација и провера безбедносног квалитета.

# 1 Идентитет, аутентикација и Контрола приступа заснована на улогама

Безбедност почиње раздвајањем идентитета, пријаве и овлашћења. Систем најпре треба да поуздано препозна субјекат, затим да процени његов актуелни статус, а тек потом да провери шта тај субјекат сме да уради. Када се ти кораци помешају, грешке се лако сакрију иза једне успешне пријаве.

Контрола приступа заснована на улогама је важан зато што права не додељује произвољно сваком налогу. Улоге изражавају одговорности у организацији, па тим може разумљиво да управља приступом, да га прегледа и да га укине када више није потребан.




*Слика 1. Ко приступа систему и зашто идентитет претходи свакој одлуци*

Безбедносна одлука настаје повезивањем приказаних појмова.

**Циљ вежбе**

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

## 1.1 Ментални модел приступа

Контрола приступа заснована на улогама је важан зато што права не додељује произвољно сваком налогу. Улоге изражавају одговорности у организацији, па тим може разумљиво да управља приступом, да га прегледа и да га укине када више није потребан.

- Успешна пријава потврђује идентитет, али сама по себи не даје право на ресурс.
- Улога треба да буде читљива пословна одговорност, а дозвола мала и проверљива радња.
- Промена статуса или улоге мења приступ одмах, без ослањања на застарелу претпоставку клијента.

**Питање за дискусију**

За једну административну радњу објасните разлику између идентитета, улоге, дозволе и опсега у коме дозвола важи.

## 1.2 Како се ова тема види у развоју

Дизајн почиње питањима ко су актери, које одговорности имају и над којим опсегом раде. Сервер доноси коначну одлуку; интерфејс само помаже кориснику да не бира радње које вероватно неће проћи.

Честе грешке које треба препознати

- Мешање аутентикације и ауторизације у једну проверу.
- Давање широке улоге зато што је брже од обликовања једне дозволе.
- Ослањање на сакривено дугме као на безбедносну контролу.

**Веза са осталим темама**

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

## 1.3 Пример: оператор добија нову одговорност

Оператер је до јуче прегледао извештаје, а данас привремено помаже тиму који одобрава промене на осетљивим ресурсима. Најједноставније решење делује као додела администраторске улоге. Међутим, та одлука често отвара много више радњи него што је стварно потребно, а касније је тешко утврдити које право је било оправдано и када треба да нестане.

- Прво се одређује конкретна радња коју оператор треба да изврши, а не назив најшире постојеће улоге.
- Затим се проверава опсег: да ли право важи за цео систем, један домен или само ограничено време.
- На крају се дефинише ревизија или истек, како привремена потреба не би остала трајна привилегија.

**Критеријуми решења**

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

## 1.4 Дизајнерска одлука: улога није дозвола

Улога је начин да организација групише одговорности, док дозвола изражава најмању радњу коју систем штити. То раздвајање делује као додатни посао на почетку, али смањује цену сваке касније промене. Када се дода нова радња, тим не мора да измишља нову комбинацију корисника и изузетака, већ процењује којој одговорности припада и над којим опсегом важи.

- Улоге треба именовати по одговорности, не по техничком слоју апликације.
- Дозвола треба да описује радњу и ресурс довољно прецизно да може да се провери.
- Ефективна права настају из улоге, опсега и актуелног статуса, а не из једног статичког поља корисника.

## 1.5 Како знамо да модел приступа ради

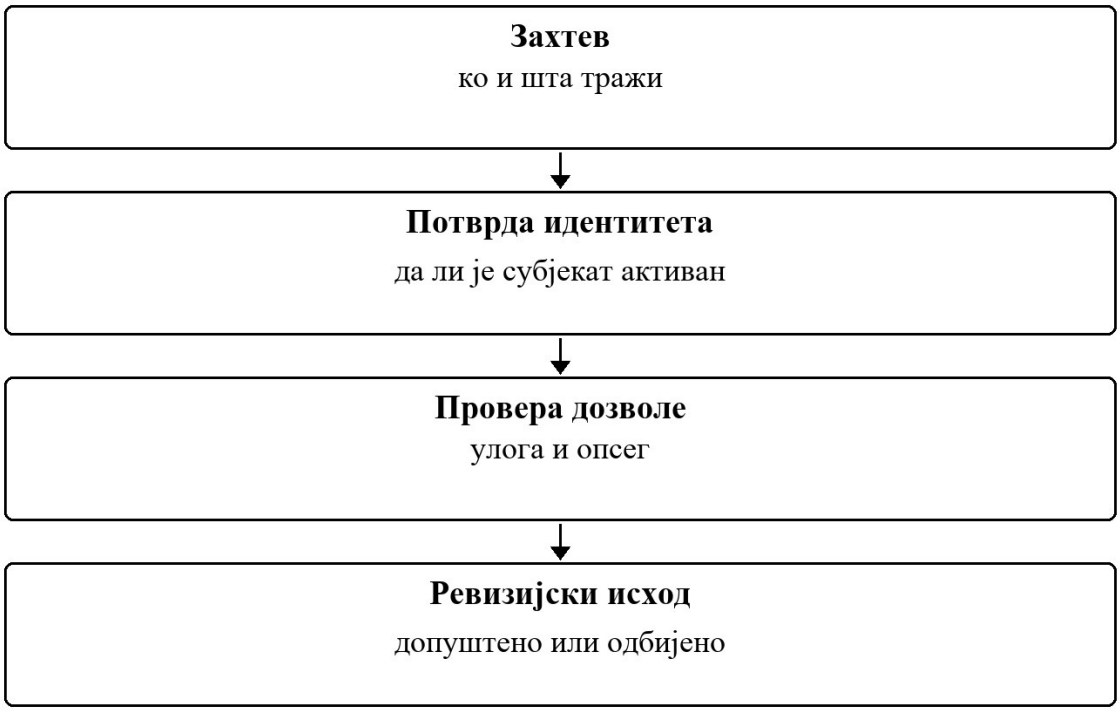
Најкориснији доказ није само успешна пријава. Потребно је показати и да систем одбија радњу када изостане једна потребна чињеница: активан идентитет, одговарајућа дозвола или исправан опсег. Такви негативни случајеви штите модел од случајног ширења права кроз касније измене.

- Тестови пореде очекивано допуштену и одбијену радњу над истим типом ресурса.
- Ревизијски запис бележи ко је покушао радњу, шта је захтевано и какав је исход.
- Преглед права треба да објасни основ приступа, а не само назив корисничке улоге.

**Самостална провера**

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

## 1.6 Шема одлуке о приступу




*Слика 2. Шема одлуке о приступу*

Пријава је само једна фаза. Право приступа настаје тек када систем провери цео контекст.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

## 1.7 Поређење основних појмова идентитета

*Табела 2. Појам и Питање на које одговара*

| Појам | Питање на које одговара | Типична грешка |
|---|---|---|
| Идентитет | Ко је субјекат? | Мешање особе и техничког налога. |
| Аутентикација | Да ли је тврдња о идентитету потврђена? | Успешна пријава се тумачи као широко овлашћење. |
| Ауторизација | Да ли је радња допуштена? | Провера се ради само у корисничком интерфејсу. |
| Сесија | У ком привременом контексту приступ важи? | Токен се третира као трајно право. |

**Тумачење поређења**

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

## 1.8 Ток размишљања при одлуци о приступу

Када систем прими захтев, корисно је посматрати одлуку као низ питања, а не као једну методу која враћа да или не. Свако питање смањује скуп могућих грешака и оставља јасан траг за каснији преглед.

1. Да ли је субјекат познат и активан?

2. Да ли је захтевана радња дефинисана као дозвола?

3. Да ли улога и опсег дају то право баш у овом тренутку?

4. Који ревизијски запис описује успех или одбијање?

**Исход учења**

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

**Примена на пројекту**

На додељеној пројектној целини применити принцип из теме „Идентитет, аутентикација и Контрола приступа заснована на улогама". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

## 1.9 Извршиви пример

Ауторизација приступа извештајима на основу улога. `RbacPolicy` подразумевано одбија приступ; пријављен налог мора имати тражену дозволу.

*Пример 1. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.*

```
cd examples/oib-dotnet/vezba-01-identitet-rbac
dotnet run --project src/Oib.Vezba01.ConsoleUi
dotnet test Oib.Vezba01.sln
```

*Табела 3. Провера и Садржај*

| Провера | Садржај |
|---|---|
| Сценарио | Улога без дозволе `reports:export` покушава извоз. |
| Тестови | `RbacPolicyTests`, `AuthorizeAccessHandlerTests` |
| Доказ | `AccessAuditEntry` бележи и одобрен и одбијен приступ. |

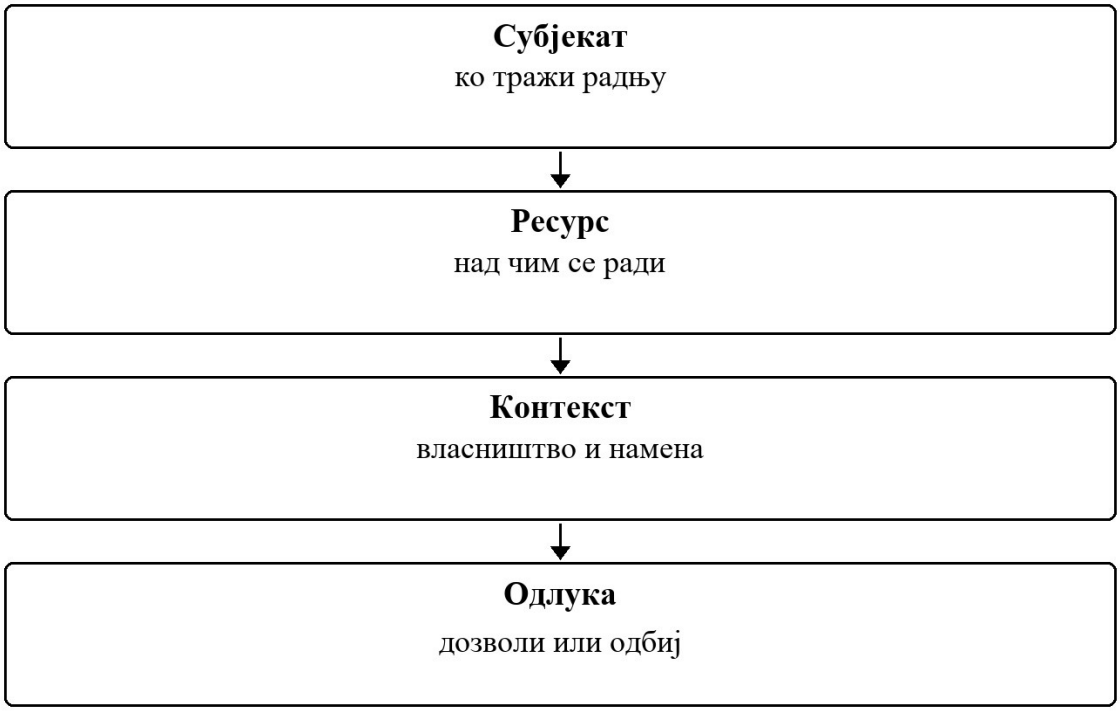
**Задатак уз пример**

Додати атрибут `IsActive` актеру и правило да деактивиран налог нема приступ иако има улогу. Правило додати у `RbacPolicy`, увести нов код одлуке и покрити га тестом.

# 2 Ауторизација над ресурсом и класификација података

Ауторизација има смисла тек када је везана за конкретан ресурс и његов контекст. Корисник може имати легитимну улогу, а ипак не сме да чита, мења или дели баш тај запис. Зато се одлука не завршава провером типа ендпоинта или назива улоге.

Класификација података даје исти језик власницима, развоју и операцијама. Када систем зна колико је податак осетљив, може да примени одговарајући приступ, приказ, чување и евиденцију без ослањања на нечије сећање.




*Слика 3. Зашто познавање адресе ресурса не значи право приступа*

Безбедносна одлука настаје повезивањем приказаних појмова.

**Циљ вежбе**

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

## 2.1 Одлука мора имати контекст

Класификација података даје исти језик власницима, развоју и операцијама. Када систем зна колико је податак осетљив, може да примени одговарајући приступ, приказ, чување и евиденцију без ослањања на нечије сећање.

- Провера права укључује субјект, радњу, ресурс и његову припадност.
- Одбијање не треба да открива садржај нити постојање туђег осетљивог ресурса.
- Класификација није етикета за документацију, већ улаз у правила руковања подацима.

**Питање за дискусију**

Који ресурс носи ризик хоризонталног приступа и које информације одлука мора да узме у обзир?

## 2.2 Како се ова тема види у развоју

За сваку значајну операцију тим формулише и позитиван и негативан сценарио. Негативан сценарио проверава да правилно пријављен корисник не може да заобиђе власништво променом идентификатора или позивом Програмски интерфејс-ја ван интерфејса.

Честе грешке које треба препознати

- Провера улоге без провере односа према конкретном ресурсу.
- Филтрирање листе у клијенту без исте провере на серверу.
- Снижавање класификације без образложења и трага промене.

**Веза са осталим темама**

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

## 2.3 Пример: исправна улога, погрешан запис

Два члана тима имају исту улогу и обојица могу да прегледају захтеве. Један мења идентификатор у адреси захтева и долази до туђег записа. Систем који проверава само улогу сматра захтев дозвољеним, иако се променио најважнији део контекста: однос корисника према конкретном ресурсу.

- Одлука укључује идентитет, тражену радњу, ресурс и припадност ресурса одговарајућем домену или власнику.
- Исти принцип важи за Програмски интерфејс позив, извоз података и позадинску обраду, не само за екран који корисник види.
- Одговор на одбијени приступ треба да буде користан клијенту, али не сме да открије податке о заштићеном запису.

**Критеријуми решења**

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

## 2.4 Дизајнерска одлука: податак носи обавезе

Класификација не говори само колико је податак важан. Она утиче на начин приказа, извоз, дељење, чување и брисање. Када те последице нису јасно везане за класификацију, сваки нови екран или интеграција мора поново да погађа како треба руковати информацијом.

- Класификација има пословно значење које сви чланови тима тумаче на исти начин.
- Правила за приказ и извоз треба да буду строжа када последице грешке расту.
- Власник податка одговара за оправданост промене класификације, а систем чува траг те промене.

## 2.5 Како знамо да је ауторизација потпуна

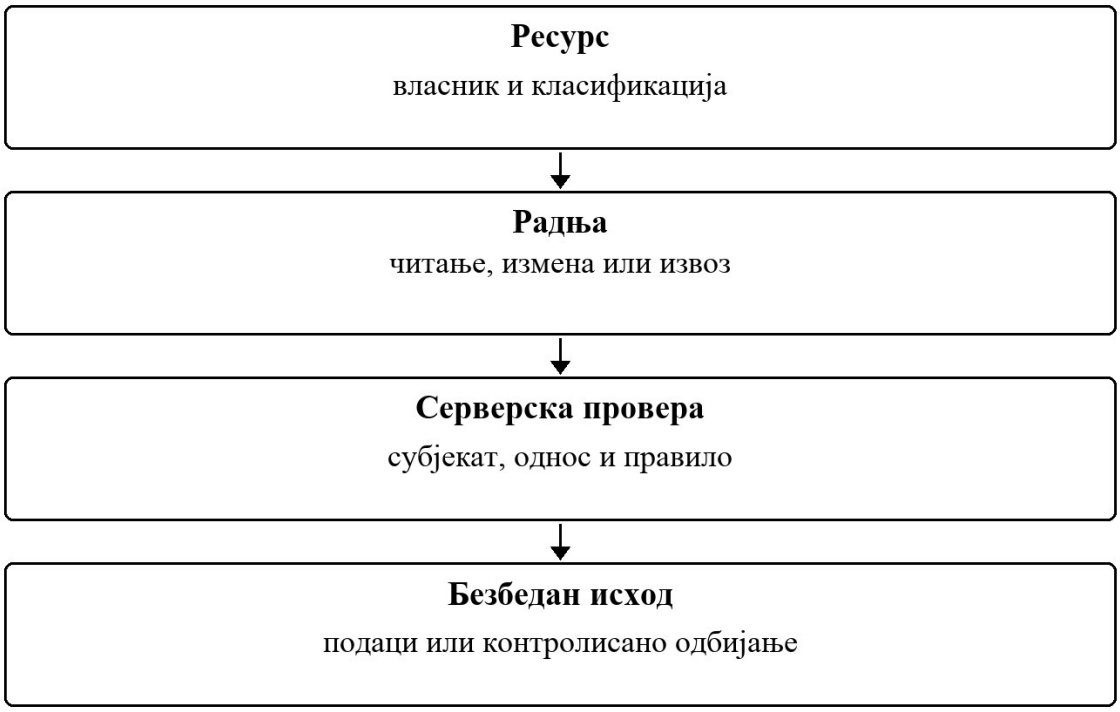
Приступ треба проверити кроз стварну границу система, а не само кроз кориснички интерфејс. То значи да директан Програмски интерфејс захтев, позадински процес и извоз не могу прескочити исто правило. Негативни тестови зато нису додатак после имплементације, већ најјаснији опис границе приступа.

- Систем једнако штити ресурс када се захтев пошаље ван стандардног екрана.
- Одбијени захтев не враћа детаље који помажу да се мапирају туђи подаци.
- Промена класификације и промена власништва остављају довољно трага за касније преглед.

**Самостална провера**

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

## 2.6 Шема заштите једног ресурса




*Слика 4. Шема заштите једног ресурса*

Идентификатор у адреси не представља право приступа. Однос субјекта према ресурсу проверава се на серверу.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

## 2.7 Нивои провере приступа

*Табела 4. Ниво и Шта проверава*

| Ниво | Шта проверава | Зашто није довољан сам |
|---|---|---|
| Пријава | Идентитет субјекта. | Не говори шта субјекат сме да уради. |
| Улога | Општи скуп одговорности. | Не зна однос према конкретном запису. |
| Ресурс | Власништво, припадност и класификацију. | Мора се комбиновати са радњом и политиком. |
| Контекст | Време, стање и пословно оправдање. | Може променити закључак за исту улогу. |

**Тумачење поређења**

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

## 2.8 Животни циклус податка

Заштита података не завршава се у тренутку читања. Исти податак пролази кроз креирање, употребу, дељење, чување и уклањање. Свака фаза поставља друго питање о дозвољеном приступу и потребном трагу.

1. При креирању се одређују власник и класификација.

2. При коришћењу се проверава сврха и опсег приступа.

3. При дељењу се проверава граница поверења и минимални скуп података.

4. При чувању и уклањању примењују се рокови чувања и правила ревизијског евидентирања.

**Исход учења**

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

**Примена на пројекту**

На додељеној пројектној целини применити принцип из теме „Ауторизација над ресурсом и класификација података". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

## 2.9 Извршиви пример

`ResourceReadPolicy` проверава дозволу, власништво и класификацију конкретног записа. Провера се извршава на серверу за сваки захтев.

*Пример 2. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.*

```
cd examples/oib-dotnet/vezba-02-resurs-klasifikacija
dotnet run --project src/Oib.Vezba02.ConsoleUi
dotnet test Oib.Vezba02.sln
```

*Табела 5. Провера и Садржај*

| Провера | Садржај |
|---|---|
| Сценарио | Корисник погађа идентификатор туђег записа. |
| Тестови | `ResourceReadPolicyTests`, `ReadResourceHandlerTests` |
| Доказ | `ResourceAccessAuditEntry` садржи исход и стабилан код одлуке. |

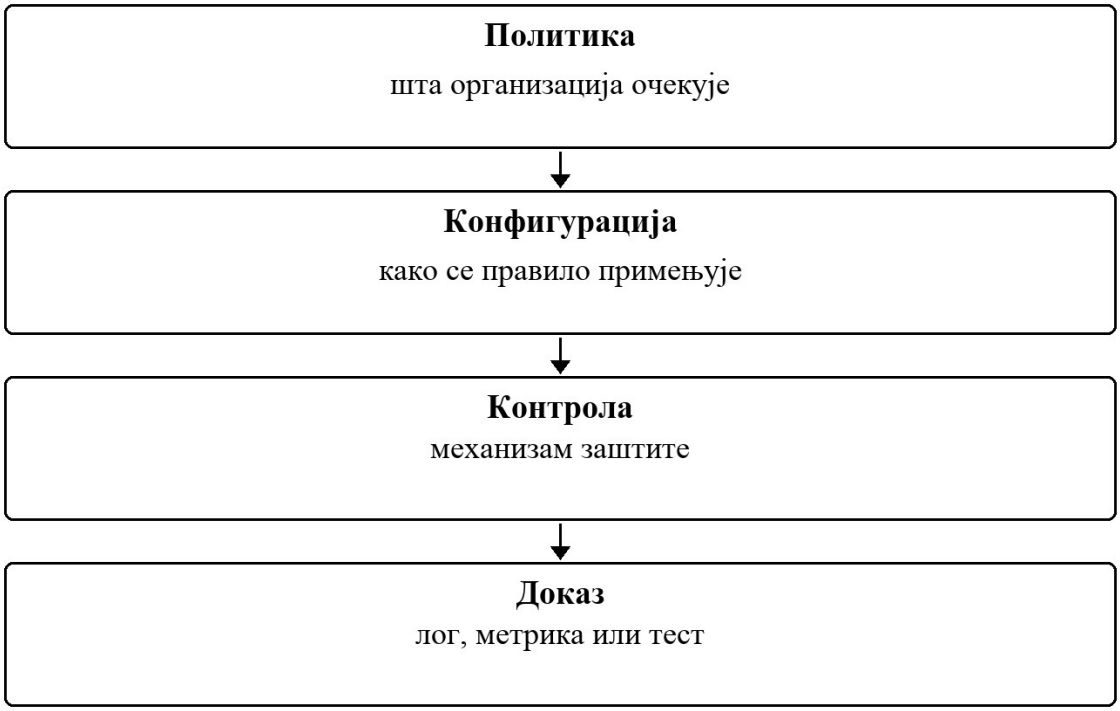
**Задатак уз пример**

Увести радњу измене записа: мења га само власник, без обзира на `records:read:any`. Додати нову политику и случај употребе поред постојећих, без мењања `ResourceReadPolicy`.

# 3 Политике, конфигурација и безбедносна видљивост

Безбедносна правила постају поуздана тек када су видљива, верзионисана и проверљива. Правило расуто кроз неколико метода није лако објаснити, прегледати нити променити без нежељених последица. Политика зато представља договорено правило, а конфигурација његову примену у конкретном окружењу.

Видљивост не служи само реаговању на инцидент. Она омогућава тиму да разуме одлуку система, прати одступање од очекиваног стања и повеже догађаје кроз различите слојеве апликације.




*Слика 5. Експлицитна правила уместо безбедности скривене у коду*

Безбедносна одлука настаје повезивањем приказаних појмова.

**Циљ вежбе**

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

## 3.1 Правило без доказа је само намера

Видљивост не служи само реаговању на инцидент. Она омогућава тиму да разуме одлуку система, прати одступање од очекиваног стања и повеже догађаје кроз различите слојеве апликације.

- Нова верзија политике не брише разлог због ког је стара одлука некада била исправна.
- Конфигурациона вредност има власника, значење и очекивани опсег.
- Корелациони идентификатор повезује један безбедносни ток кроз слојеве система.

**Питање за дискусију**

Које безбедносно правило би требало да буде засебан, читљив артефакт у вашој целини и који доказ показује да ради?

## 3.2 Како се ова тема види у развоју

Тим бира неколико кључних одлука које мора моћи да објасни из лога и теста. То нису сви догађаји система, већ они чији би нејасан исход отежао истрагу, преглед приступа или корекцију конфигурације.

Честе грешке које треба препознати

- Уређивање објављене политике на месту без историје.
- Тајне у конфигурационим датотекама или логовима.
- Метрика без јасног питања на које треба да одговори.

**Веза са осталим темама**

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

## 3.3 Пример: промена правила без губитка историје

Тим пооштрава правило за приступ административном интерфејсу. Ако старо правило само препише новим, касније не може да објасни зашто је ранији приступ био дозвољен нити да реконструише које је очекивање тада важило. Верзионисање не служи бирократији, већ очувању смисла историјских одлука.

- Политика описује намеру и важење, док конфигурација чува вредности којима се та намера примењује у окружењу.
- Свака промена која утиче на одлуку има власника, датум и јасан разлог.
- Лог, метрика или тест дају доказ да систем ради према активном правилу, а не само да је правило записано.

**Критеријуми решења**

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

## 3.4 Дизајнерска одлука: правило мора имати границе

Политика постаје корисна када је довољно прецизна да људи доносе доследне одлуке, а довољно читљива да се може објаснити без читања изворног кода. Добро правило наводи на шта се односи, ко је власник, када важи и шта се дешава ако се правила сукобе.

- Конфликт политика решава се унапред договореним правилом, често рестриктивнијом одлуком.
- Конфигурација не мења смисао политике без видљивог процеса одобравања.
- Безбедносна контрола има власника и очекивани доказ, иначе нико не прати да ли је престала да ради.

## 3.5 Видљивост као способност тима

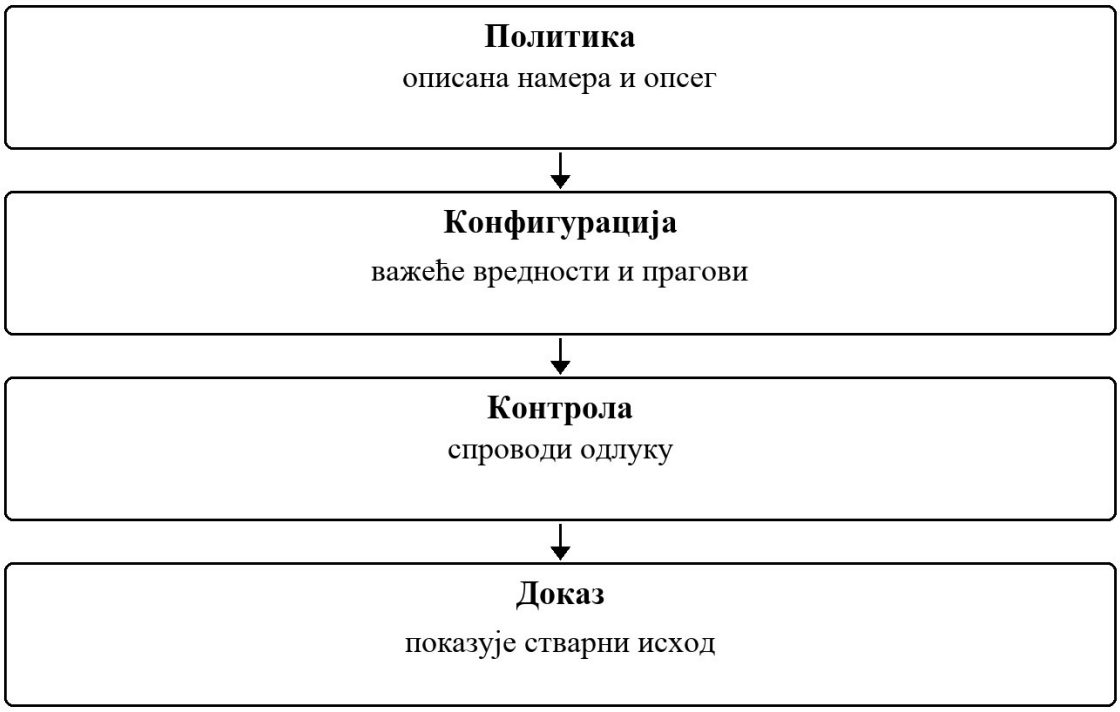
Опсервабилност подразумева да се за значајну одлуку може пронаћи одговарајући контекст: место настанка, ток кроз слојеве система и разлог успешног или одбијеног исхода. Корелациони идентификатор повезује записе који припадају истој операцији.

- Технички логови разликују се од безбедносно значајних ревизијских записа.
- Метрика има назив, власника и прецизно дефинисано питање на које одговара.
- Тајне, токени и непотребни лични подаци не бележе се у логове нити у ознаке метрика.

**Самостална провера**

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

## 3.6 Шема од правила до доказа




*Слика 6. Шема од правила до доказа*

Правило може бити добро написано, а контрола ипак неефективна. Доказ повезује очекивање са реалним понашањем.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

## 3.7 Политика, процедура и контрола

*Табела 6. Елемент и Улога*

| Елемент | Улога | Пример доказа |
|---|---|---|
| Политика | Одређује правило и циљ заштите. | Верзионисан текст са власником. |
| Процедура | Описује како људи или систем спроводе правило. | Преглед корака или аутоматизовани ток. |
| Контрола | Спречава, открива или ограничава ризик. | Тест, лог или резултат провере. |
| Метрика | Показује тренд или одступање. | Дефинисан праг и извор података. |

**Тумачење поређења**

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

## 3.8 Како се бира безбедносна метрика

Метрика је корисна само ако води ка одлуци. Зато се не почиње бројем, већ питањем које оператер или власник система мора да реши. Затим се бира извор, период посматрања и праг при коме је потребна акција.

1. Које понашање желимо да разумемо или ограничимо?

2. Који догађаји поуздано представљају то понашање?

3. Ко је власник прага и шта ради када се праг пређе?

4. Како разликујемо нормалну промену рада од безбедносног одступања?

**Исход учења**

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

**Примена на пројекту**

На додељеној пројектној целини применити принцип из теме „Политике, конфигурација и безбедносна видљивост". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

## 3.9 Извршиви пример

`ConfigurationDriftDetector` пореди активну конфигурацију са усвојеним баселине-ом. Контроле имплементирају `IConfigurationControl`; налаз означава слабљење заштите.

*Пример 3. Покретање из репозиторијума наставног портала; потребан је доднет 8 СДК.*

```
cd examples/oib-dotnet/vezba-03-politike-konfiguracija
dotnet run --project src/Oib.Vezba03.ConsoleUi
dotnet test Oib.Vezba03.sln
```

*Табела 7. Провера и Садржај*

| Провера | Садржај |
|---|---|
| Сценарио | Минимална дужина лозинке или захтев за администраторски Вишефакторска аутентикација ослаби у односу на баселине. |
| Тестови | `ConfigurationControlTests`, `DetectConfigurationDriftHandlerTests` |
| Доказ | `DriftReport` садржи цоррелатион ИД и верзију баселине-а. |

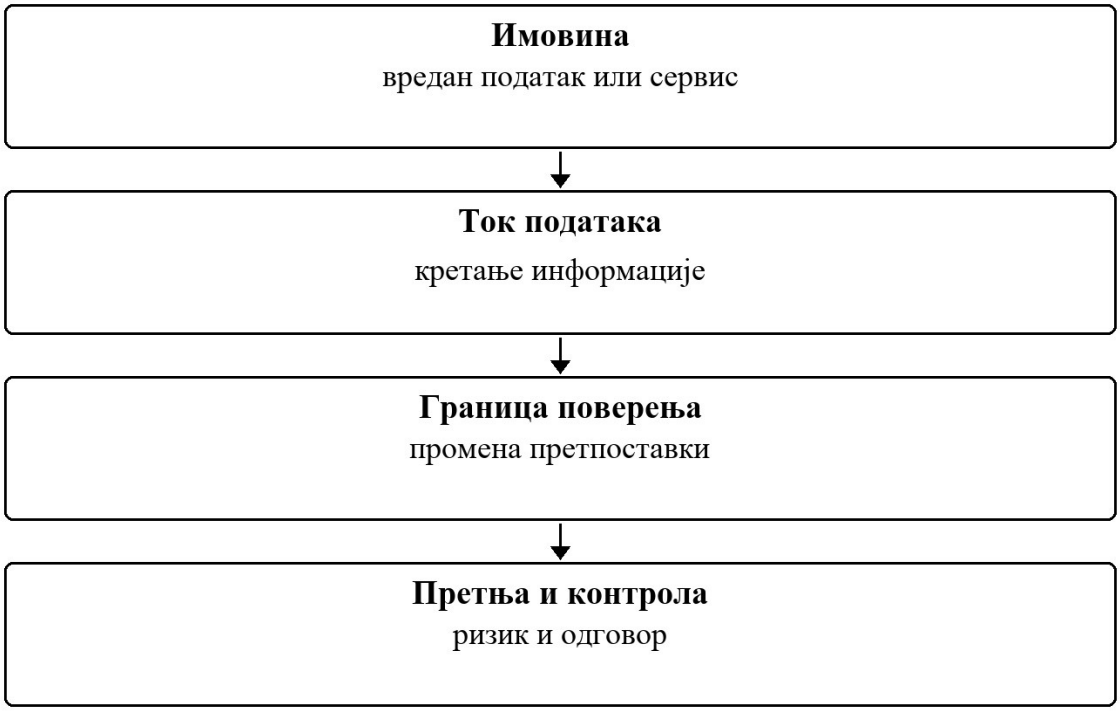
**Задатак уз пример**

Додати контролу за максимално трајање сесије: проширити `SecurityBaseline` и `SecurityConfiguration`, написати нову `IConfigurationControl` класу и тест који показује да дужа сесија од дозвољене даје налаз.

# 4 Имовина, границе поверења и моделовање претњи

Добра безбедносна одлука не полази од листе познатих решења, већ од вредне имовине, тока података и граница поверења. Тек тада тим може да препозна шта би могло поћи по злу и која контрола има смисла за конкретан ризик.

Моделовање претњи повезује техничку структуру система са пословним последицама и омогућава да се погрешне претпоставке уоче пре него што постану део стабилне архитектуре.




*Слика 7. Разумевање онога што штитимо пре избора контроле*

Безбедносна одлука настаје повезивањем приказаних појмова.

**Циљ вежбе**

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

## 4.1 Модел пре контроле

Моделовање претњи повезује техничку структуру система са пословним последицама и омогућава да се погрешне претпоставке уоче пре него што постану део стабилне архитектуре.

- Имовина има власника, значај и животни циклус.
- Спољна компонента не добија поверење само зато што је интегрисана.
- Претња постаје корисна када води до захтева, контроле и начина провере.

**Питање за дискусију**

Нацртајте један ток осетљивог податка и означите место на коме се претпоставка о поверењу мења.

## 4.2 Како се ова тема види у развоју

Архитектурни дијаграм постаје основа безбедносне анализе када приказује податке, актере и претпоставке уз сваку важну границу. Тим затим бира неколико реалних сценарија злоупотребе и проверава их тестом или прегледом дизајна.

Честе грешке које треба препознати

- Инвентар који постоји само ради евиденције, без власништва и значаја.

- Општи каталог претњи који није повезан са стварним системом.
- Контрола изабрана пре разумевања ризика који треба да смањи.

**Веза са осталим темама**

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

## 4.3 Пример: извоз из интерног система

Интерни сервис припрема извоз осетљивих података за други систем. Тим га доживљава као безбедан јер је сервис „унутра“, али сам прелазак података у други систем мења претпоставке. Потребно је знати који податак путује, ко прима податак, шта може поћи по злу и како систем спречава или бар открива нежељен исход.

- Имовина обухвата налоге, кључеве, сервисне идентитете, конфигурацију и пословне записе, а не само базу података.
- Граница поверења може бити Програмски интерфејс позив, ред порука, административни интерфејс или извоз у датотеку.
- Модел претњи обухвата одабране реалне сценарије, одговарајуће контроле и начин њихове провере.

**Критеријуми решења**

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

## 4.4 Дизајнерска одлука: прво модел, затим алат

Избор безбедносног алата заснива се на имовини коју треба заштитити, граници коју треба надзирати и сценарију који треба открити. Модел претњи усмерава избор контроле и омогућава процену њене вредности.

- Критичност имовине одређује колико брзо се реагује и колико је доказа потребно.
- Ток података открива места на којима информација може бити измењена, изгубљена или погрешно изложена.
- Претња добија приоритет према утицају, вероватноћи и реалним постојећим контролама.

## 4.5 Одржавање модела претњи

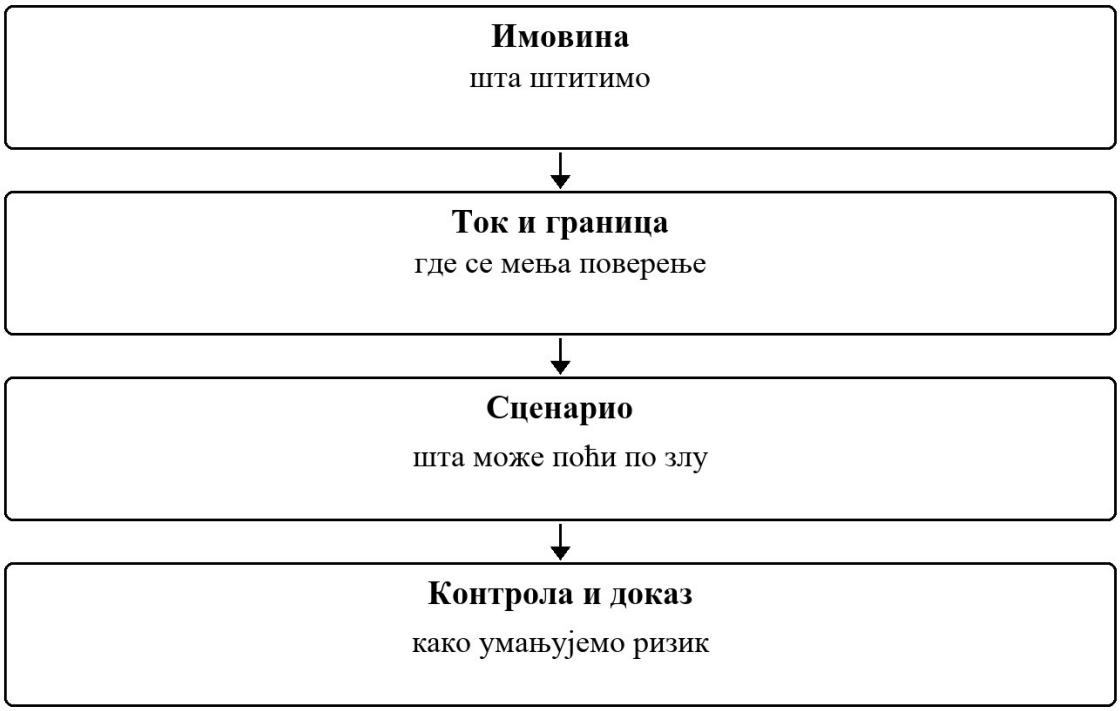
Модел претњи није документ који се напише једном на почетку семестра. Мења се када се дода нови улаз, интеграција, начин чувања података или привилегована радња. Свака већа архитектонска промена је прилика да се провери да ли су старе претпоставке и даље тачне.

- Дијаграм се ажурира када ток података или граница поверења стварно промени понашање система.
- За одабрани сценарио постоји веза до контроле, теста или прегледа који га проверава.
- Преостали ризик се записује јасно, уместо да се претвара да ниједна претња више не постоји.

**Самостална провера**

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

## 4.6 Шема модела претњи




*Слика 8. Шема модела претњи*

Претња добија смисао тек када се веже за конкретну имовину, ток и последицу.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

## 4.7 Имовина, рањивост и претња

*Табела 8. Појам и Значење*

| Појам | Значење | Питање за анализу |
|---|---|---|
| Имовина | Оно чија вредност захтева заштиту. | Шта губимо ако је угрожена? |
| Рањивост | Слабост коју је могуће искористити. | Где систем нема довољну заштиту? |
| Претња | Могући узрок нежељеног исхода. | Ко или шта може активирати слабост? |
| Ризик | Комбинација вероватноће и последице. | Шта прво треба умањити? |

**Тумачење поређења**

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

## 4.8 Читање архитектонске скице кроз безбедност

Архитектонска скица добија безбедносну вредност када се преко компоненти уцртају подаци, идентитети и границе поверења. Није потребно цртати сваку класу. Довољно је показати делове кроз које пролази вредна информација и одлуке које мењају њен статус.

1. Означити улазе које контролише корисник или спољашњи сервис.

2. Означити место где се идентитет или дозвола поново проверавају.

3. Означити складишта, кључеве и интеграције које мењају последицу инцидента.

4. Уз сваку границу записати једну реалну претпоставку која може бити погрешна.

**Исход учења**

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

**Примена на пројекту**

На додељеној пројектној целини применити принцип из теме „Имовина, границе поверења и моделовање претњи". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

## 4.9 Извршиви пример

Процена сценарија претње повезује имовину, ток података и границу поверења. `ThreatRiskCalculator` рачуна ризик; демонстрациона политика захтева третман при вредности 24 или већој.

*Пример 4. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.*

```
cd examples/oib-dotnet/vezba-04-threat-modeling
dotnet run --project src/Oib.Vezba04.ConsoleUi
dotnet test Oib.Vezba04.sln
```

*Табела 9. Провера и Садржај*

| Провера | Садржај |
|---|---|
| Сценарио | Извоз личних података стиже неовлашћеном примаоцу. |
| Тестови | `ThreatRiskCalculatorTests`, `AssessThreatModelHandlerTests` |
| Доказ | `ThreatModelReport` приказује сценарије по ризику и предложене контроле. |

**Задатак уз пример**

Додати резидуални ризик: `ThreatScenario` добија процену ефикасности контроле, а извештај приказује ризик пре и после контроле. Правило сместити у доменски сервис и покрити граничним тестовима.

## Контролна тачка КТ1 Основна имплементација и безбедносни модел

Прва контролна тачка одржава се у термину 4. вежбе. Тим приказује обухват свих додељених целина, безбедносни модел и први заокружен функционални ток са серверском заштитом и негативним тестом.

Обавезно за све тимове

1. За СВАКУ додељену целину: листа случај употребе-ова из спецификације, редослед имплементације и означени предуслови (Тапиз листа планираних задатака).
2. Један обједињени домен модел / скица тока, кључни ентитети, статуси и власништво података; минимална сецурити матрица Субјецт–Ацтион–Ресоурце–Allow/Deny за релевантне операције.
3. Репозиторијум: основна структура апликације, РЕАДМЕ са стартовањем, изградња који пролази, почетни Континуирана интеграција и Тапиз задатак → бранцх → ПР пракса.
4. Примарна целина: најмање један заокружен функционалан ток који пролази кроз апликациону логику и persistence/simulator, са демонстрацијом нормалног исхода; за једноставније целине очекују се бар две кључне операције (нпр. унос + промена статуса).
5. Серверска заштита конкретне операције (scope/ownership/role према домену), валидација улаза и један АУТОМАТИЗОВАН негативни тест; не сматра се довољном заштита само кроз УИ.
6. Тхреат модел свих додељених целина: ассет → misuse/pretnja → контрола → тест → евиденце, уз приказ бар једне труст границе.
7. Migracije/seed или еквивалентно поновљиво тестно стање; структурисани događaj/audit за релевантну промену без тајни.
8. Минимални међутимски уговор прегледан са суседним тимом; ако имплементација није спремна, заменска компонента + позитивни и негативни одговор.

**Приказ**

Модел и листа планираних задатака, покренут нормалан сценарио, негативан аутоматски тест и конкретан план завршетка до КТ2 у термину 8. вежбе.

**Не тражити у овој фази**

Пуна реализација druge/treće целине. Продукциони симулатор.

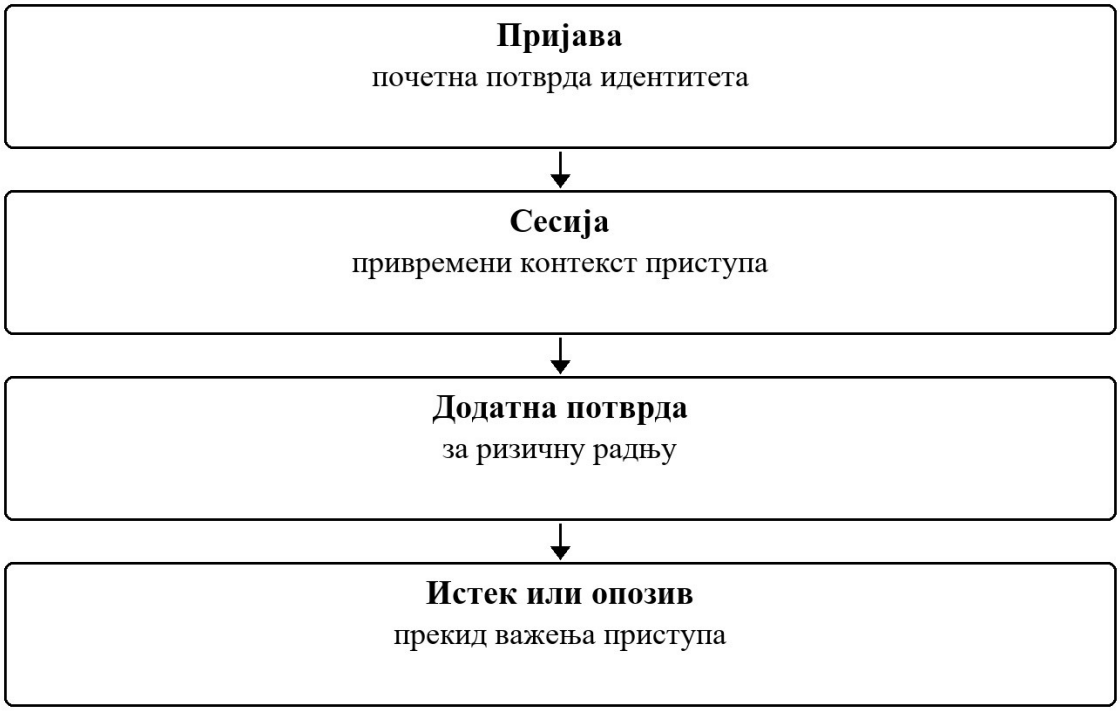
**Термин и обухват**

Вежба 1–4 · Вежба 4 Исти захтеви приказани су на картици „Контролне тачке“.

# 5 Вишефакторска аутентикација, сесије, сервиси и тајне

Идентитет није трајно доказан једном пријавом. Ризик радње, трајање сесије, врста уређаја и промена привилегија утичу на то колико је додатна потврда потребна. Оперативна безбедност зато прати приступ и након почетне аутентикације.

Вишефакторска потврда и временски ограничене привилегије смањују последице украденог креденцијала. Управљање тајнама штити везе међу сервисима, где непажња често остане скривена јер нема корисничког екрана.




*Слика 9. Контрола приступа кроз време, а не само у тренутку пријаве*

Безбедносна одлука настаје повезивањем приказаних појмова.

**Циљ вежбе**

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

## 5.1 Приступ има рок и контекст

Вишефакторска потврда и временски ограничене привилегије смањују последице украденог креденцијала. Управљање тајнама штити везе међу сервисима, где непажња често остане скривена јер нема корисничког екрана.

- Сесија може изгубити важност пре планираног истека.
- Додатна потврда прати ризик радње, не само тип корисника.
- Сервисни идентитет има мали, јасно оправдан опсег, као и људски идентитет.

**Питање за дискусију**

Која радња заслужује додатну потврду идентитета и који догађај би требало да опозове постојећу сесију?

## 5.2 Како се ова тема види у развоју

Развојни тим унапред одређује које ситуације мењају ниво поверења: промена привилегије, приступ осетљивом податку или сумњива пријава. Тајне се референцирају из безбедног извора и никада се не преносе кроз код, тестне исписе или историју репозиторијума.

Честе грешке које треба препознати

- Токен третиран као вечна дозвола.
- Администраторска права додељена без рока и прегледа.
- Једна широка тајна дељена међу више независних сервиса.

**Веза са осталим темама**

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

## 5.3 Пример: сесија после промене привилегије

Корисник се пријавио ујутру, а касније током дана добија виши ниво приступа. Ако систем не преиспита постојећу сесију, корисник може извршити ризичну радњу без додатне потврде која би била потребна да се пријављује у том тренутку. Обрнуто, одузета привилегија мора заиста да престане да важи, а не да чека крај дуготрајне сесије.

- Сесија представља привремени контекст приступа, а не трајну потврду поверења.
- Додатна аутентикација примењује се када ризик радње захтева виши ниво потврде идентитета.
- Сервисни налог има најмањи потребан опсег, рок важења и контролисану ротацију тајне.

**Критеријуми решења**

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

## 5.4 Дизајнерска одлука: поверење се обнавља

Сесија олакшава рад кориснику, али њен комфор не сме постати трајно поверење. Систем мора знати када се околности мењају довољно да претходна потврда више није довољна. То могу бити промена привилегије, необичан уређај, ризична радња или сигнал да је налог угрожен.

- Истек ограничава трајање поверења чак и када нема видљивог инцидента.
- Опозив реагује на конкретну промену ризика и не чека да сесија природно нестане.
- Додатни фактор доказује присуство или поседовање независног средства, а не понавља само исту лозинку.

## 5.5 Тајне као део архитектуре

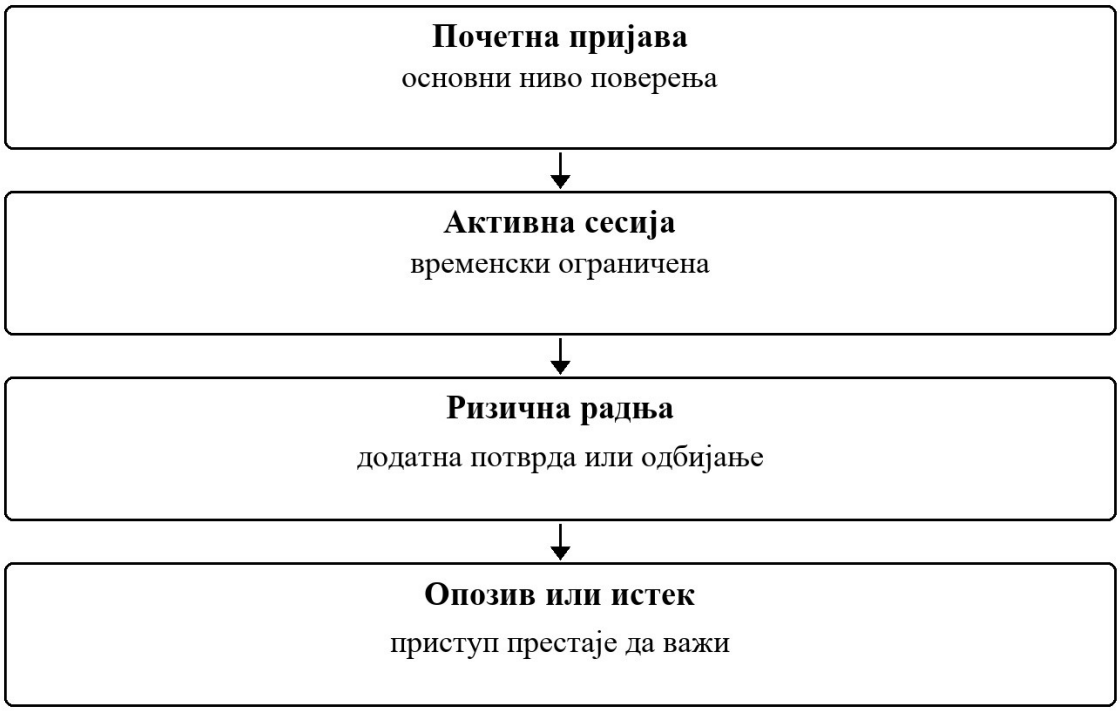
Тајна није конфигурациона вредност као свака друга. Њено излагање може дати приступ без видљивог корисничког екрана, нарочито између сервиса. Зато развојни процес дефинише одакле тајна долази, ко је користи, када се ротира и како се проверава да није случајно завршила у репозиторијуму или логу.

- Сваки сервисни идентитет има сврху и најмањи потребан опсег.
- Ротација се планира пре истека, уместо да се чека прекид рада.
- Тестови проверавају понашање при опозиву или истеку без приказивања стварних вредности тајне.

**Самостална провера**

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

## 5.6 Шема животног циклуса поверења




*Слика 10. Шема животног циклуса поверења*

Поверење се не чува заувек. Систем га обнавља или опозива када се промени ризик.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

## 5.7 Различите врсте идентитета

*Табела 10. Идентитет и Намена*

| Идентитет | Намена | Посебан ризик |
|---|---|---|
| Људски корисник | Интерактивне радње и одговорност. | Крађа креденцијала или преширока улога. |
| Сервисни налог | Комуникација међу компонентама. | Тајна без рока или превелик опсег. |
| Привремени приступ | Кратка ризична интервенција. | Право остане активно након потребе. |
| Администраторски налог | Измене са великим утицајем. | Недостатак додатне потврде и аудита. |

**Тумачење поређења**

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

## 5.8 Од тајне до безбедне употребе

Безбедно управљање тајном почиње пре њеног првог коришћења. Потребно је знати власника, сврху, компоненту која је користи и начин ротације. Сама вредност тајне треба да остане ван кода, екрана и записа који нису за то намењени.

1. Тајна се издаје само идентитету који јој је стварно потребан.

2. Систем прати истек и планира ротацију пре прекида рада.

3. Логови бележе употребу и неуспех без приказивања вредности тајне.

4. Опозив ограничава последицу сумње да је тајна компромитована.

**Исход учења**

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

**Примена на пројекту**

На додељеној пројектној целини применити принцип из теме „Вишефакторска аутентикација, сесије, сервиси и тајне". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

## 5.9 Извршиви пример

`StepUpAuthenticationPolicy` проверава да ли сесија има довољно свежу Вишефакторска аутентикација потврду за ризичну операцију. Одлука разликује одбијање и потребу за новом потврдом.

*Пример 5. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.*

```
cd examples/oib-dotnet/vezba-05-mfa-sesije-tajne
dotnet run --project src/Oib.Vezba05.ConsoleUi
dotnet test Oib.Vezba05.sln
```

*Табела 11. Провера и Садржај*

| Провера | Садржај |
|---|---|
| Сценарио | Преузета, опозвана или давно потврђена сесија покушава поверљив извоз. |
| Тестови | `StepUpAuthenticationPolicyTests`, `AuthorizeRiskyOperationHandlerTests` |
| Доказ | `StepUpDecision` враћа код одлуке и ознаку да ли се тражи Вишефакторска аутентикација. |

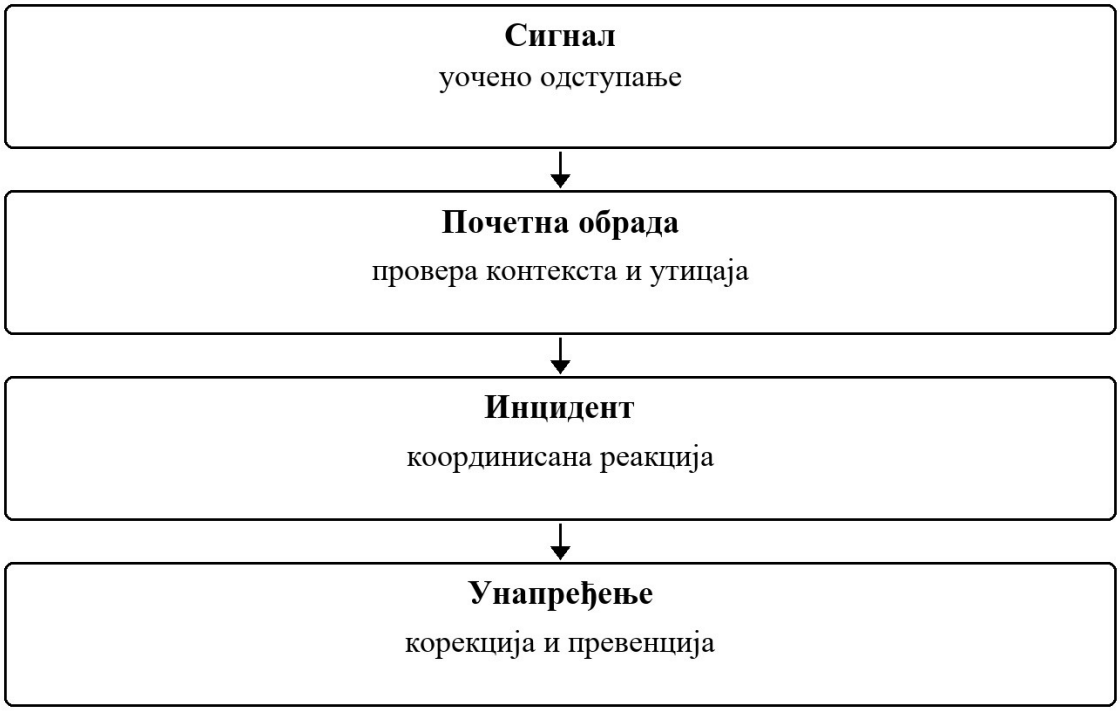
**Задатак уз пример**

Додати максималну старост саме сесије: сесија издата пре више од осам сати одбија се без обзира на Вишефакторска аутентикација. Увести нов код одлуке и тест за граничну вредност.

# 6 Детекција, инцидент и рањивости

Безбедносни догађај није аутоматски инцидент. Систем најпре препознаје сигнал, затим га ставља у контекст и тек онда одређује да ли је потребна реакција. Такав ток спречава и игнорисање проблема и непотребно алармирање због сваког одступања.

Управљање инцидентом даје структуру тренутку када је најлакше изгубити контекст. Рањивост постаје решив проблем када је повезана са имовином, приоритетом, власником и доказом да је корекција проверена.




*Слика 11. Од сигнала ка проверљивој и смиреној реакцији*

Безбедносна одлука настаје повезивањем приказаних појмова.

**Циљ вежбе**

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

## 6.1 Сигнал тражи контекст

Управљање инцидентом даје структуру тренутку када је најлакше изгубити контекст. Рањивост постаје решив проблем када је повезана са имовином, приоритетом, власником и доказом да је корекција проверена.

- Праг детекције треба да има смисао и разлог, не само произвољну бројку.
- Затварање упозорења чува образложење, јер је то знање за следећи сличан случај.
- Рањивост није решена променом статуса, већ провером да је ризик заиста смањен.

**Питање за дискусију**

Који догађај би у вашем систему био користан сигнал, али не и довољан доказ инцидента? Који контекст недостаје?

## 6.2 Како се ова тема види у развоју

Тим бира мали број сигнала који су разумљиви оператеру. За сваки описује нормално понашање, разлог активирања, одговорну особу и безбедан начин провере. Тако се детекција дизајнира као производна могућност, а не као споредни лог.

Честе грешке које треба препознати

- Упозорење без власника и правила за почетну обраду.
- Аутоматско затварање без доказа о решавању узрока.
- Скенирање зависности без утврђеног начина процене и праћења налаза.

**Веза са осталим темама**

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

## 6.3 Пример: више неуспелих пријава

Низ неуспелих пријава може указивати на заборављену лозинку, проблем интеграције или покушај злоупотребе. Сам број неуспеха није довољан за закључак. Почетна обрада укључује порекло покушаја, осетљивост налога и наставак обрасца након упозорења.

- Детекција описује образац који захтева проверу, без аутоматског проглашавања сваке грешке инцидентом.
- Почетна обрада бележи одлуку и разлог затварања упозорења.
- Затварање рањивости захтева доказ да је изложеност уклоњена или формално прихваћена као преостали ризик.

**Критеријуми решења**

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

## 6.4 Дизајнерска одлука: сигнал није пресуда

Детекција покушава да примети промену понашања, не да аутоматски чита намеру корисника. Квалитетан сигнал зато наводи образац, праг и контекст који недостаје за коначну одлуку. Тиме оператер може брзо да разликује нормалан проблем рада система од потенцијалног безбедносног догађаја.

- Праг се бира према нормалном понашању система, а не према случајном броју.
- Упозорење има озбиљност, власника и рок до ког се мора погледати.
- Инцидент се отвара када контекст покаже стварни утицај или вероватну злоупотребу.

## 6.5 Учење након догађаја

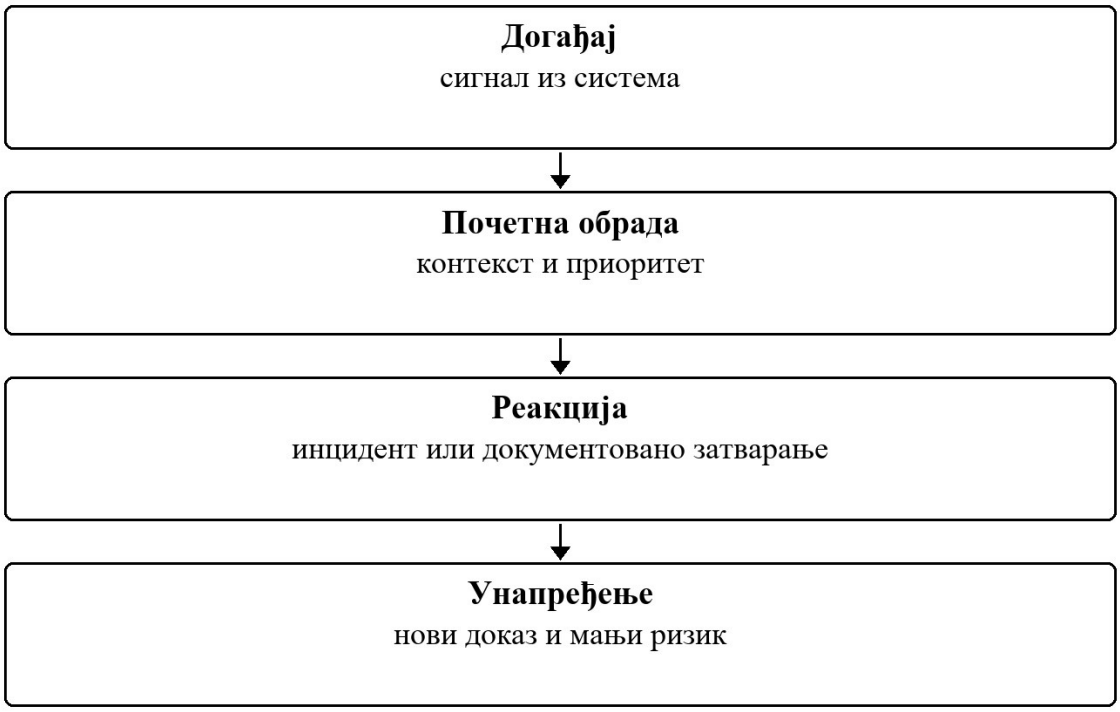
Добар пост-инцидент преглед није потрага за особом која је погрешила. Његов циљ је да пронађе где су недостајали сигнал, заштитна провера, јасна одговорност или припрема за опоравак. Резултат треба да мења систем или процес на начин који се може проверити.

- Хронологија одваја чињенице од претпоставки насталих под притиском.
- Акције након инцидента имају власника и проверљив завршетак.
- Нови сценарио се додаје у тестове или оперативне вежбе, како се исто знање не би изгубило.

**Самостална провера**

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

## 6.6 Шема одговора на безбедносни догађај




*Слика 12. Шема одговора на безбедносни догађај*

Није сваки сигнал инцидент, али сваки значајан исход оставља знање корисно за следећу одлуку.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

## 6.7 Сигнал, упозорење и инцидент

*Табела 12. Стање и Шта представља*

| Стање | Шта представља | Потребна реакција |
|---|---|---|
| Сигнал | Сиров догађај или одступање. | Сачувати контекст и проверити правило. |
| Упозорење | Сигнал који је прешао дефинисан праг. | Почетна обрада и процена приоритета. |
| Инцидент | Потврђен или вероватан безбедносни утицај. | Координисана реакција и следљив ток. |
| Налаз рањивости | Потенцијална изложеност коју треба проценити. | Власник, рок и доказ корекције. |

**Тумачење поређења**

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

## 6.8 Ток управљања рањивошћу

Налаз постаје користан тек када се повеже са стварном имовином и њеном изложеношћу. Исти технички проблем нема исти приоритет на изолованом развојном рачунару и на јавно доступној услузи која обрађује осетљиве податке.

1. Потврдити да се налаз односи на конкретну компоненту и активну верзију.

2. Проценити утицај у контексту доступности, података и граница поверења.

3. Одредити корекцију, компензациону контролу или образложено прихватање ризика.

4. Затворити налаз тек када доказ потврди да је изложеност смањена.

**Исход учења**

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

**Примена на пројекту**

На додељеној пројектној целини применити принцип из теме „Детекција, инцидент и рањивости". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

## 6.9 Извршиви пример

`RepeatedFailedLoginRule` препознаје најмање три неуспешне пријаве у десет минута. `IncidentFactory` из сигнала формира инцидент са одређеном озбиљношћу.

*Пример 6. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.*

```
cd examples/oib-dotnet/vezba-06-detekcija-incident
dotnet run --project src/Oib.Vezba06.ConsoleUi
dotnet test Oib.Vezba06.sln
```

*Табела 13. Провера и Садржај*

| Провера | Садржај |
|---|---|
| Сценарио | Узастопни покушаји пријаве са исте адресе. |
| Тестови | `RepeatedFailedLoginRuleTests`, `IncidentFactoryTests`, `DetectIncidentsHandlerTests` |
| Доказ | `Incident` садржи идентификатор, озбиљност, сажетак и време отварања. |

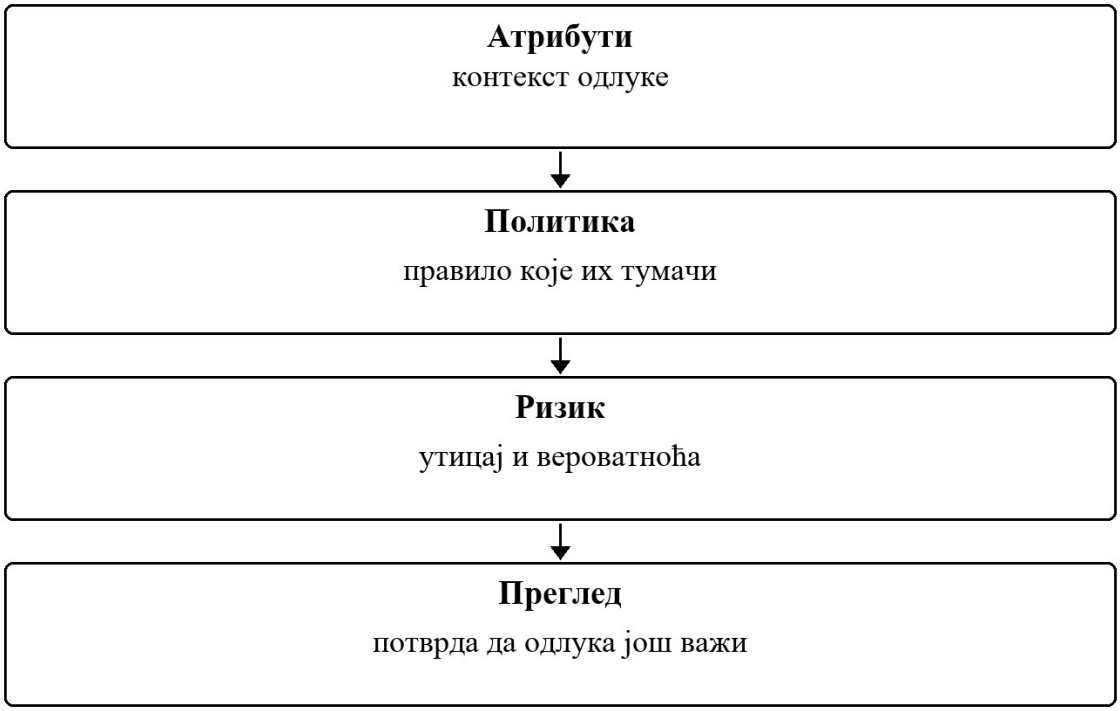
**Задатак уз пример**

Додати правило које препознаје пассворд спраиинг: иста адреса неуспешно покушава пријаву на више различитих налога. Написати нову `IDetectionRule` класу и регистровати је у корен композиције-у.

# 7 Атрибути, ризик и периодични преглед приступа

Контрола приступа заснована на улогама даје стабилну основу, али сложеније одлуке често зависе и од контекста: припадности, врсте података, времена, стања ресурса или нивоа ризика. Атрибутска правила уводе тај контекст без претварања сваке могуће комбинације у нову улогу.

Регистар ризика и редован преглед приступа спречавају да застареле одлуке остану трајне претпоставке. Евидентирају преостали ризик, одговорно лице и рок за поновно разматрање одлуке.




*Слика 13. Када улоīа више није довољна за добру одлуку*

Безбедносна одлука настаје повезивањем приказаних појмова.

**Циљ вежбе**

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

## 7.1 Право приступа није заувек

Регистар ризика и редован преглед приступа спречавају да застареле одлуке остану трајне претпоставке. Евидентирају преостали ризик, одговорно лице и рок за поновно разматрање одлуке.

- Атрибути се читају из поузданог, јасног контекста.
- Исто стање мора довести до истог резултата политике.
- Ризик укључује имовину, претњу, контролу и преосталу изложеност.

**Питање за дискусију**

Коју одлуку не бисте смели да заснивате само на улози и који додатни атрибут јој даје смисао?

## 7.2 Како се ова тема види у развоју

Тим издваја одлуке које не могу поштено да стану у назив једне улоге. Затим их записује као правило које се може тестирати са неколико супротних контекста. Преглед приступа проверава да ли је некадашња пословна потреба и даље стварна.

Честе грешке које треба препознати

- Увођење атрибута без јасног извора и значења.

- Правило које зависи од скривеног стања и даје необјашњив резултат.
- Конфликт дужности откривен тек након што је штета могућа.

**Веза са осталим темама**

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

## 7.3 Пример: иста улога, различит тренутак

Два оператера имају исту улогу, али један ради на инциденту који му је додељен, док други ради на другом домену. Ако политика гледа само улогу, обојица би могла да одобре исту ризичну измену. Атрибути као што су припадност домену, стање инцидента и тренутно одобрење дају одлуци контекст који назив улоге сам не може да носи.

- Атрибутска одлука остаје разумљива само ако је извор сваког атрибута познат и поуздан.
- Правило треба да даје исти резултат за исти снимак контекста, како би могло да се тестира и објасни.
- Преглед приступа враћа тим на питање да ли право и даље има пословни разлог, чак и када је некада било правилно додељено.

**Критеријуми решења**

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

## 7.4 Дизајнерска одлука: контекст без хаоса

Атрибути не треба да постану скривени скуп изузетака који нико не разуме. Сваки атрибут мора имати јасно значење, извор и тренутак на који се односи. Политика затим наводи како се ти подаци комбинују, па одлука може бити поновљена, тестирана и објашњена без ослањања на интуицију имплементатора.

- Атрибути се прикупљају из ауторитативних извора, а не из произвољног захтева клијента.
- Правила треба да буду мала и састављена тако да се конфликт може објаснити.
- Контекст одлуке се бележи довољно да касније преглед разуме резултат без чувања осетљивих детаља.

## 7.5 Ризик као разговор о одлуци

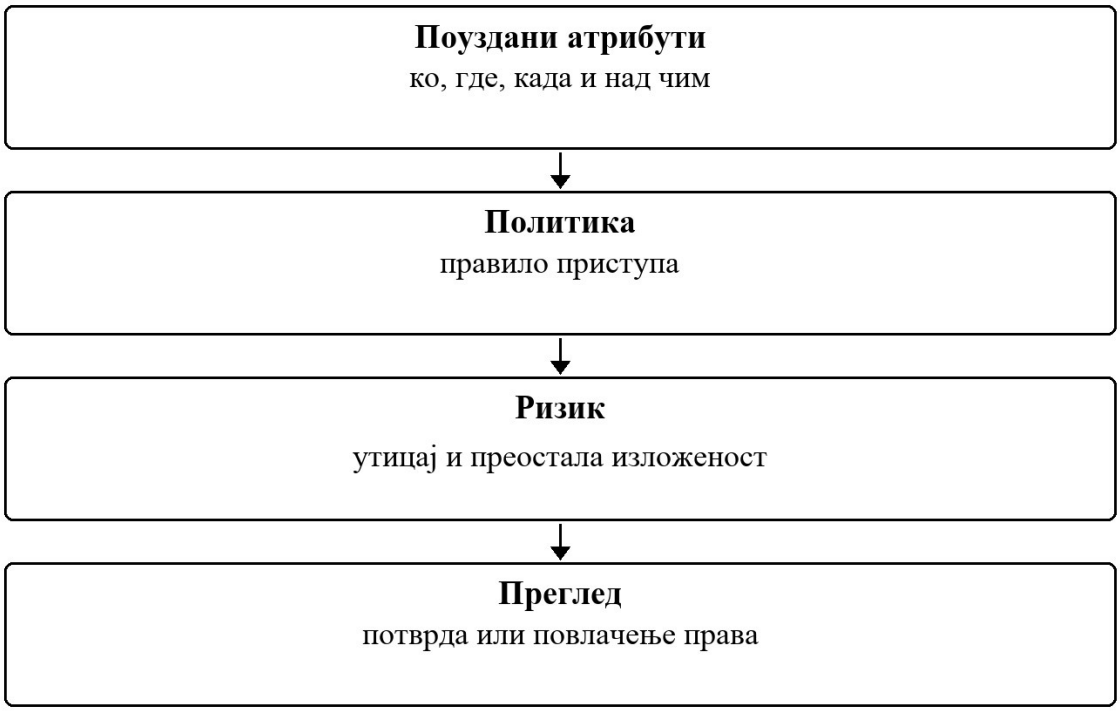
Регистар ризика омогућава поређење утицаја, вероватноће, постојећих контрола и преостале изложености. За прихваћени ризик бележе се одговорно лице, образложење и датум наредног прегледа.

- Ризик повезује конкретну имовину, претњу и контролу.
- Преглед приступа и преглед ризика имају ритам, власника и очекивани исход.
- Сегрегација дужности спречава комбинације права које би једној особи дале превелику контролу.

**Самостална провера**

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

## 7.6 Шема контекстуалне одлуке




*Слика 14. Шема контекстуалне одлуке*

Контекст даје прецизност одлуци, а редован преглед проверава да ли одлука и даље има смисла.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

## 7.7 Контрола приступа заснована на улогама и АБАЦ у истој одлуци

*Табела 14. Приступ и Снага*

| Приступ | Снага | Ограничење |
|---|---|---|
| Контрола приступа заснована на улогама | Јасне, стабилне одговорности. | Тешко изражава време, власништво и стање. |
| АБАЦ | Користи богат контекст одлуке. | Тражи поуздане атрибуте и читљива правила. |
| Комбинација | Улога даје основу, атрибути прецизирају. | Потребно је пажљиво објаснити приоритет правила. |
| СоД | Спречава ризичне комбинације права. | Мора се проверавати кроз ефективна права. |

**Тумачење поређења**

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

## 7.8 Од ризика до одлуке о прихватању

Ризик се не уклања увек у потпуности. Неке мере би биле прескупе, неке би зауставиле важан рад, а неке зависе од спољне стране. Тада је важно да преостали ризик буде видљив, образложен и временски ограничен, а не заборављен.

1. Описати имовину, сценарио и последицу без општих формулација.

2. Навести постојеће контроле и шта оне заиста покривају.

3. Оценити шта остаје незаштићено након тих контрола.

4. Одредити власника који прихвата ризик и датум следећег прегледа.

**Исход учења**

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

**Примена на пројекту**

На додељеној пројектној целини применити принцип из теме „Атрибути, ризик и периодични преглед приступа". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

## 7.9 Извршиви пример

`RiskBasedAccessPolicy` проверава контекст кроз скуп `IAccessRule` правила. Приступ захтева одговарајућу улогу, уређај, локацију и прихватљив ризик.

*Пример 7. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.*

```
cd examples/oib-dotnet/vezba-07-abac-rizik-pregled
dotnet run --project src/Oib.Vezba07.ConsoleUi
dotnet test Oib.Vezba07.sln
```

*Табела 15. Провера и Садржај*

| Провера | Садржај |
|---|---|
| Сценарио | Исправна улога користи се са непознатог уређаја или уз висок ризик. |
| Тестови | `AccessRuleTests`, `RiskBasedAccessPolicyTests`, `EvaluateAccessHandlerTests` |
| Доказ | `AccessDecision` даје разлог одлуке; `AccessReviewItem` одређује рок и власника прегледа. |

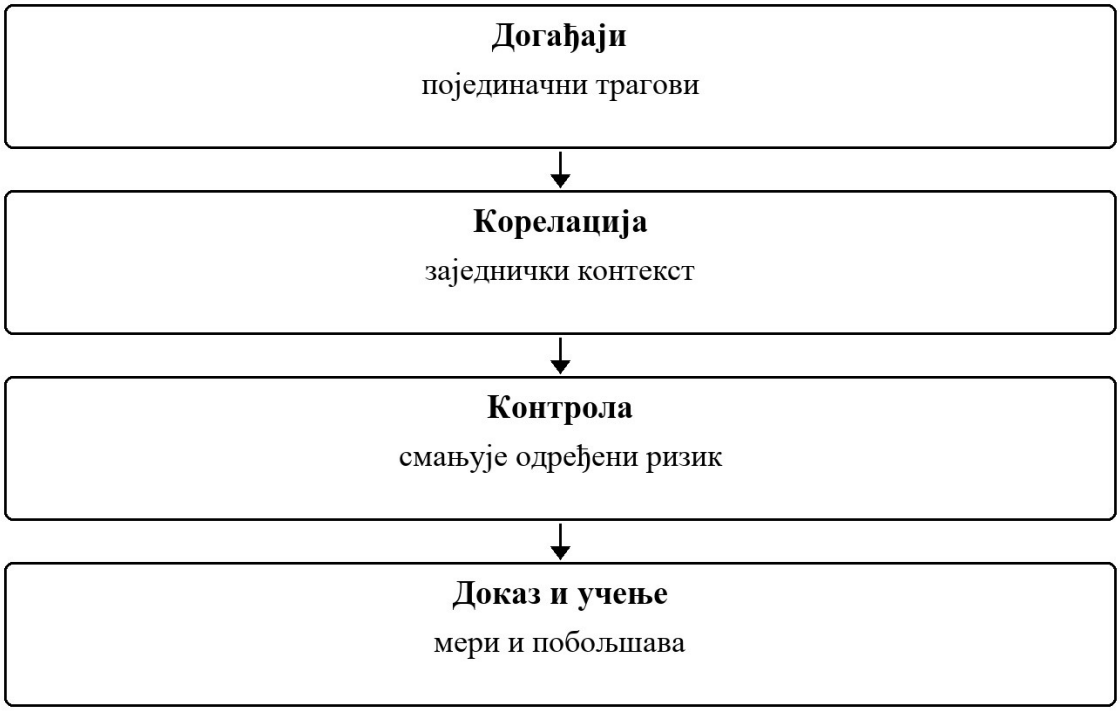
**Задатак уз пример**

Додати правило радног времена: ограничен ресурс доступан је само радним данима од 8 до 18 часова. Време проследити кроз контекст, а не читати га из система унутар правила.

# 8 Корелација догађаја, ефективност контрола и учење

Завршна слика безбедности не састоји се од појединачних контрола, већ од њихове везе. Догађаји добијају смисао када се корелишу, контрола добија вредност када постоји свеж доказ да ради, а инцидент постаје прилика да се систем побољша без прикривања грешака.

Мерење ефективности спречава лажни осећај сигурности. Контрола која постоји, али је погрешно подешена, никада тестирана или без власника, не заслужује исто поверење као контрола са проверљивим доказом.




*Слика 15. Безбедност као процес који се мери и унапређује*

Безбедносна одлука настаје повезивањем приказаних појмова.

**Циљ вежбе**

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

## 8.1 Контрола има смисао тек уз доказ

Мерење ефективности спречава лажни осећај сигурности. Контрола која постоји, али је погрешно подешена, никада тестирана или без власника, не заслужује исто поверење као контрола са проверљивим доказом.

- Корелација повезује догађаје кроз време, актере и ресурсе, а не само по једној поруци лога.
- Одговор са већим последицама захтева људску одлуку и јасан траг одобрења.
- Пост-инцидент преглед испитује систем и процес, не тражи најближег кривца.

**Питање за дискусију**

Изаберите једну контролу и покажите који ризик ублажава, који доказ чува и како бисте приметили да је престала да ради.

## 8.2 Како се ова тема види у развоју

Добра безбедносна анализа показује узрочну везу: коју имовину штитимо, који сценарио разматрамо, која контрола делује и како знамо да њено понашање још увек одговара намери. Кратак, јасан доказ вреди више од дуге листе функционалности.

Честе грешке које треба препознати

- Закључивање из једног догађаја без ширег контекста.
- Аутоматска акција са великом последицом без заштитне провере.
- Оцена контроле само по томе да ли је имплементирана.

**Веза са осталим темама**

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

## 8.3 Пример: контрола постоји, али нема свеж доказ

Систем има правило које ограничава приступ осетљивом ресурсу. Правило је било успешно тестирано пре неколико месеци, али се у међувремену променио модел улога и додат је нови улаз у систем. Без новог доказа тим зна да контрола постоји, али не зна да ли још покрива стварни ризик. Ефективност зато укључује свежину, опсег и резултат провере.

- Корелација повезује низ догађаја у јединствен приказ понашања система.
- Мера ефективности прати да ли контрола има власника, доказ и покривеност релевантног сценарија.
- Аутоматизован одговор може убрзати реакцију, али радња са великом последицом захтева људску потврду и ревизијски траг.

**Критеријуми решења**

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

## 8.4 Дизајнерска одлука: корелација пре закључка

Појединачан догађај често има више могућих објашњења. Корелација повезује време, актера, ресурс и ток рада, па тим може да разликује случајну грешку од обрасца који заслужује реакцију. Циљ није прикупити највише података, већ повезати оне податке који мењају одлуку.

- Корелациони идентификатор повезује намеру, обраду и исход једне радње.
- Правила корелације морају бити објашњива, посебно када утичу на приоритет упозорења.
- Аутоматизација предлаже или ограничава одговор када је последица грешке велика.

## 8.5 Ефективност је више од постојања контроле

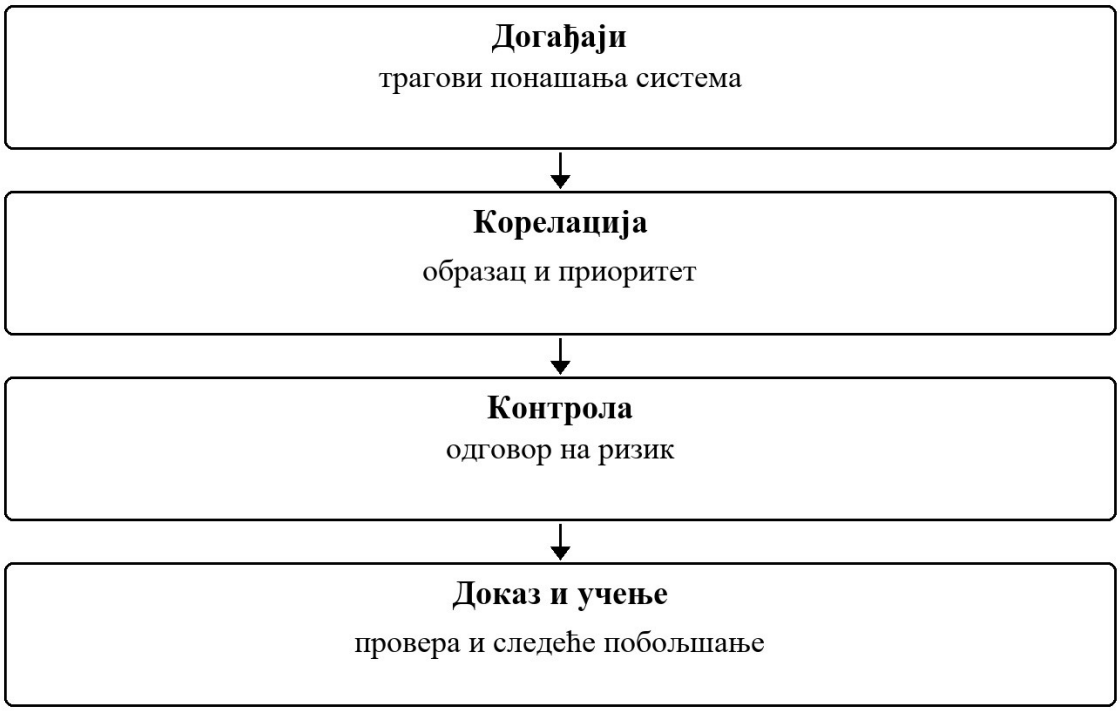
Контрола може бити имплементирана, али погрешно подешена, заобиђена новим током или застарела после промене система. Зато се њена ефективност процењује кроз доказ: последњи успешан тест, покривени сценарио, власника и способност да се проблем примети ако контрола закаже.

- Доказ се освежава када се промени релевантан ток, улога или граница поверења.
- Мера ефективности не скрива непознато, већ показује где доказа нема довољно.
- Квалитетна анализа повезује ризик, контролу, тест и преостало ограничење у једну јасну причу.

**Самостална провера**

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

## 8.6 Шема континуираног унапређивања безбедности




*Слика 16. Шема континуираног унапређивања безбедности*

Безбедност напредује кроз повратну спрегу: доказ мења разумевање ризика, а то мења контролу.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

## 8.7 Доказ, покривеност и ефективност

*Табела 16. Питање и Слаб одговор*

| Питање | Слаб одговор | Поуздан одговор |
|---|---|---|
| Да ли контрола постоји? | Класа или подешавање је присутно. | Контрола има власника, активну конфигурацију и сврху. |
| Да ли ради? | Једном је ручно проверена. | Постоји поновљив тест или актуелан оперативни доказ. |
| Шта покрива? | Претпоставља се да важи свуда. | Познати су сценарио, граница и изузеци. |
| Како знамо да је ослабила? | Проблем се види тек после инцидента. | Метрика, упозорење или редован преглед откривају одступање. |

**Тумачење поређења**

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

## 8.8 Безбедносна повратна спрега

Зрео систем не завршава безбедност имплементацијом контроле. Догађаји и тестови стварају доказ, доказ мења процену ризика, а процена ризика води ка бољој политици или другачијој контроли. Тако се избегава лажни осећај да је једном завршени посао заувек довољан.

1. Догађај или тест открива образац који захтева пажњу.

2. Корелација повезује образац са имовином, актером и контролом.

3. Тим проверава да ли постојећа контрола покрива стварни сценарио.

4. Нова одлука ствара ажурирану политику, тест или оперативну процедуру.

**Исход учења**

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

**Примена на пројекту**

На додељеној пројектној целини применити принцип из теме „Корелација догађаја, ефективност контрола и учење". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

## 8.9 Извршиви пример

`EventCorrelator` повезује догађаје у случајеве. `ControlEffectivenessCalculator` пореди удео блокираних покушаја са задатим циљем; без покушаја нема основа за оцену ефективности.

*Пример 8. Покретање из репозиторијума наставног портала; потребан је доднет 8 СДК.*

```
cd examples/oib-dotnet/vezba-08-korelacija-efektivnost
dotnet run --project src/Oib.Vezba08.ConsoleUi
dotnet test Oib.Vezba08.sln
```

*Табела 17. Провера и Садржај*

| Провера | Садржај |
|---|---|
| Сценарио | Контрола постоји, али не блокира потребан удео ризичних покушаја. |
| Тестови | `EventCorrelatorTests`, `ControlEffectivenessCalculatorTests`, `AnalyzeSecurityEventsHandlerTests` |
| Доказ | `SecurityAnalysisReport` приказује повезане случајеве и резултате мерења. |

**Задатак уз пример**

Додати време догађаја и мерити колико је прошло од првог до последњег догађаја у случају. Проширити `CorrelationCase` и написати тест за случај са једним догађајем.

## Контролна тачка КТ2 Завршна демонстрација и провера безбедносног квалитета

Друга контролна тачка одржава се у термину 8. вежбе. Тим демонстрира све обавезне случајеве употребе свих додељених целина у одобреном обиму, њихово повезивање, безбедносне одлуке и поновљиво покретање, уз ажурну документацију.

Обавезно за све тимове

1. Сви обавезни случајеви употребе AKTIVNOG/ODOBRENOG обухвата целина; ако се пуни нормативни обухват из СКУТУМ спецификације смањује, НАСТАВНИ ТИМ мора то унапред експлицитно објавити као ревизију.
2. Енд-то-енд демо: почетно стање → акција → одлука dozvoli/odbij → релевантан security/audit траг → коначан статус.
3. Унит + негативни сецурити + одговарајући integracioni/contract тестови по релевантној целини, Континуирана интеграција греен, документоване ревизије ПР.
4. Цлеан цлоне, миграције и seed/demo подаци раде према РЕАДМЕ-у.
5. API/event/policy уговори, тхреат модел, Записи о архитектонским одлукама, евиденција тестирања, индивидуални доприноси и ресидуал риск су ажурни.
6. Међутимски интеграција са реалним адаптером где је доступна; само заменска компонента не приказивати као завршену реалну интеграцију.

Додатно за тимове са 3 целине

- Трећа целина мора имати јавно одобрен опсег и извршив безбедносни ток са аутоматизованим тестовима; комплетан нормативни обим је обавезан осим ако је наставни тим формално променио спецификацију.

**Приказ**

Повезани енд-то-енд сценарио, позитиван и негативан тест, уговори и индивидуално образложење рада. Контролне тачке и термини одбране пројекта су одвојене обавезе.

**Термин и обухват**

Вежба 5–8 · Вежба 8 Исти захтеви приказани су на картици „Контролне тачке“.

## Сажетак: безбедност као следљив, доказив процес

Вежбе примењују исти аналитички след: имовина → претња или злоупотреба → безбедносни захтев → контрола → безбедносни тест → доказ. Поступак се примењује на аутентикацију, привилеговани приступ и анализу путања напада, уз прилагођавање нивоу посматраног система.

*Табела 18. Ниво и Шта уводи*

| Ниво | Шта уводи |
|---|---|
| P1 — основни | Идентитет, ресурси, класификација, ауторизација, политике и аудит. |
| P2 — оперативни | Вишефакторска аутентикација, сесије, тајне, детекција, инциденти и рањивости. |
| P3 — напредни | Механизам политика, преглед приступа, ризик, корелација и аутоматизација одговора. |

**Одговорност студента**

Тим је одговоран за разумевање захтева, образложење безбедносног модела и доказивање ефективности примењене контроле.

## Препоручена литература и документација

Литература је намењена продубљивању тема из практикума. Појмове треба повезивати са моделом претњи, безбедносним тестовима и ревизијским записима конкретног информационог система.

- ОВАСП — *Апплицатион Сецуритy Верификатион Стандард (АСВС)* и *ОВАСП Топ 10*: овасп.орг.
- НИСТ — *Дигитал Идентитy Гуиделинес (СП 800-63)*: pages.nist.gov/800-63-3.
- НИСТ — *Зеро Трустт Арцхитецтуре (СП 800-207)*: цсрц.нист.гов.
- Адам Схостацк — *Моделовање претњи: Десцриптор фор Сецуритy*.
- Енјунит документација: доцс.Енјунит.орг; Мок документација: github.com/devlooped/moq.
- Мицрософт Леарн — АСП.НЕТ Цоре Идентити, ауторизација и безбедна конфигурација: learn.microsoft.com/aspnet/core/security.
- МИТРЕ АТТ&ЦК — оквир за разумевање тактика и техника (користи се искључиво као референтни речник, не као упутство за напад): аттацк.митре.орг.

**Напомена о алатима**

Конкретни безбедносни алати (СИЕМ, ИДС, ПКИ производи) мењају се брже од основних принципа. Симулатори коришћени у практикуму опонашају њихово понашање ради вежбе — не представљају се као реални производи.